

NANDAKUMAR M

nandakumar1998@yahoo.com · +91 8680011306 · [LinkedIn](#) · [GitHub](#) · [Pentesterlab](#)

SUMMARY

Senior Application Security Engineer with extensive experience securing web, API, mobile, and cloud-native products across the full SDLC. Assessed 60+ applications, consistently uncovering what automated scanners miss through deep manual testing and adversarial thinking. Reduces organizational risk by embedding security into CI/CD pipelines, enabling developers, and driving fast remediation. Credited with 2 CVEs for discovering privilege escalation and XSS vulnerabilities in open source software (CVE-2023-2240, CVE-2023-2014).

EXPERIENCE

Senior Application Security Engineer – CyberneticsPlus Services Pvt Ltd | May 2022 – Present

- **Conducted 50+ end-to-end security assessments** across web, SaaS, API, Android, and iOS applications by identifying critical pre-production vulnerabilities including authentication bypass, insecure deserialization, and broken authorization.
- **Reduced mean-time-to-remediate by ~35%** by co-owning triage and remediation with engineering teams, providing targeted fix guidance and retest support that accelerated vulnerability closure.
- **Uncovered 120+ high/critical findings** that automated tools missed, using manual test cases aligned to OWASP Top 10, OWASP API Top 10, OWASP Mobile Top 10, and SANS Top 25 via Burp Suite Pro.
- **Performed secure code reviews** across Java, Python, and JavaScript codebases, identifying logic flaws, insecure data handling, and access control weaknesses, with actionable remediation advice delivered directly to developers.
- **Cut security defects reaching production by ~40%** by integrating SAST (Semgrep, SonarQube, Checkmarx), DAST, and SCA into CI/CD pipelines, enabling early-stage detection at commit time.
- **Led mobile security assessments** on Android and iOS: static/dynamic analysis with MobSF, Jadx, Frida, and Objection. Performed runtime analysis, SSL pinning bypass, and iOS TestFlight testing, uncovering insecure storage, hardcoded secrets, and certificate validation flaws.
- **Facilitated threat modeling** during design phases, identifying attack vectors before a line of code was written and recommending security-first architectural patterns.
- **Owned end-to-end security operations for clients across financial services, trading platforms, healthcare, SaaS, and e-commerce:** AppSec testing, penetration testing, SOC 2 compliance, endpoint security, SIEM automation (Graylog, Wazuh), and cloud security assessments on AWS and Azure.
- **Defined security metrics dashboards** tracking severity trends, vulnerability recurrence, and remediation velocity, giving leadership quantifiable visibility into risk posture over time.
- **Supported SOC 2 Type II and ISO 27001 audits** by aligning application security controls and vulnerability management workflows with compliance requirements, contributing to successful certification outcomes.
- **Delivered risk-prioritized security reports** and stakeholder briefings that translated technical findings into business impact and clear remediation priorities for both engineering leads and C-suite audiences.

Cybersecurity Trainee – AccuKnox | Dec 2021 – Apr 2022

- Deployed runtime security controls on Kubernetes workloads using KubeArmor and Cilium, enforcing least-privilege policies at the kernel level.
- Analyzed CVEs, misconfigurations, and Kubernetes-specific exposures; developed and deployed preventive policy sets using AccuKnox tooling.
- Conducted penetration testing, SIEM implementation, and proof-of-concept development for novel threat scenarios.

Penetration Tester Intern – Virtually Testing Foundation | Oct 2021 – Dec 2021 · Internship

- Executed web app pen test using Kali Linux, Burp Suite, and open-source tooling across a range of client engagements.

Penetration Tester Intern – AAITPRO | Feb 2021 – Jul 2021 · Internship

- Delivered network (internal and external) and web application penetration tests using Kali Linux, Metasploit Framework, and Burp Suite Pro.
- Developed internal tools and automation scripts in Bash and Python; contributed to ISO 27001 compliance auditing processes.

SKILLS

AppSec & Pentesting	Burp Suite Pro, MobSF, Jadx, Frida, Objection, APKTool, ADB, Nmap, SQLmap, Postman
SAST / DAST / SCA	Semgrep, SonarQube, Checkmarx, Trend Micro Cloud One
SIEM & SecOps	Graylog, Wazuh, Shuffle, WithSecure, Cloudflare, Steampipe
DevSecOps & CI/CD	Docker, Kubernetes, Helm, Jenkins, Ansible
Cloud Platforms	AWS, Azure, GCP
Programming & Scripting	Python, Bash, YAML, JavaScript
Security Frameworks	OWASP Top 10 / API Top 10 / Mobile Top 10, SANS Top 25, ISO 27001, SOC 2, Sprinto
Networking	TCP/IP, DNS, HTTP/HTTPS, REST APIs

CVE DISCLOSURES

CVE-2023-2240 Verify	Improper Privilege Management
CVE-2023-2014 Verify	Cross-site Scripting (XSS)

CERTIFICATIONS

Certified Ethical Hacker (CEH) Verify	EC-Council
Certified AppSec Practitioner (CAP) Verify	The SecOps Group
Certified in Cybersecurity (CC) Verify	ISC2

EDUCATION

B.Tech, Information Technology 2015 – 2019 CGPA:6.15	Panimalar Institute of Technology
--	-----------------------------------